

Project Proposal

Cost Aware Benchmarking of Small Open LLMs for Cross Corpus Phishing Email Detection

United International University

Course: Computer Security

ID	Name
011221002	Md. Jakaria Alam Saimon
011221376	Jahid Ibna Sinha
011221372	Nowshin Anjum Faria

1 Motivation

Phishing email is still the most common entry point for attackers. Instead of breaking any technical control, the attacker simply writes a mail that looks like it came from a trusted brand or a known person, and the victim clicks the link or gives away the credentials themselves. Blocklists and rule based spam filters have a hard time here, because the attacker only needs to change the wording a little to slip through. The situation got worse in the recent years since generative AI can now write fluent and personalized phishing emails at almost zero cost. Heiding et al. [1] showed in a real human experiment that phishing emails written by GPT-4 already get click rates comparable with emails written by human experts, so the volume and quality of attacks will only go up.

The natural question on the defense side is whether language models can also read an email the way a careful human would, and catch the manipulation in it. The recent literature says yes, large models like GPT-4 can reach very high accuracy. But almost all of these results are measured on one dataset at a time, with big commercial models, and without saying anything about what it would cost to actually run such a detector on a real mail server. For a university, a small company or really any organization in Bangladesh, cost and hardware requirements matter as much as accuracy. This is what motivates our project, we want to know what a small open model can do, how well the results hold up across different datasets, and what it costs.

There is also a practical motivation for us as a team. All the datasets used in this area (Nazario, Enron, SpamAssassin, CEAS_08 and the Kaggle phishing email set) are freely available text corpora, and small open models can be accessed through OpenRouter for a few cents. So the whole project can run in a normal laptop within a budget of five dollars, which we already verified in our preliminary experiments where the full LLM run costed less than one cent.

2 State of the Art

We reviewed five recent works from 2023 to 2026 in our literature review, they cover the main directions of the field.

The first direction is prompting large commercial models. Koide et al. [2] built ChatSpamDetector, which parses a raw email, compresses it to fit the token limit, and asks the model with a chain of thought prompt to return a verdict, a confidence score and the impersonated brand. With GPT-4 they report 99.70 percent accuracy on a balanced set of about two thousand emails, clearly above GPT-3.5, Llama 2 and Gemini Pro. Heiding et al. [1] looked at both sides, they used GPT-4 to generate phishing emails for a human experiment with 112 participants, and also asked GPT-4, Claude, Bard and LLaMA to judge suspicious emails, where the models sometimes detected the malicious intent even better than the human recipients.

The second direction is fine tuning smaller models. Uddin et al. [3] fine tuned RoBERTa on the Kaggle phishing email dataset (18,650 emails) and reached 98.45 percent accuracy, and they added LIME and Transformers Interpret so the prediction can be explained word by word. Lin et al. [4] focused on small LLMs around 3 billion parameters that run on consumer hardware. Out of the box these models perform poorly, for example Qwen2.5-1.5B got only 0.388 accuracy on SpamAssassin, but with prompt engineering, LoRA fine tuning on explanations generated by GPT-4o-mini, and a small ensemble, the small models got close to the standard sized ones. Finally Kuikel et al. [5] evaluated whether the explanations of such models can be trusted at all. Using the CC-SHAP metric on models fine tuned with classification, contrastive and DPO objectives, they found that accuracy and explanation faithfulness do not move together, the most accurate model was not the most faithful one.

In our preliminary experiments we reproduced the in-dataset part of this picture with much simpler tools. A TF-IDF and Logistic Regression baseline reached 97.9 percent accuracy on the Kaggle set, 97.3 on SpamAssassin and 99.2 on Nazario plus Enron ham, which is basically the same range that the heavier models report.

3 Research Gaps

Our preliminary experiments were designed to test what happens outside the single dataset setting, and the results point at five concrete gaps.

First, single dataset evaluation hides a big generalization gap. When we trained the baseline on the Nazario plus Enron corpus and tested it on the Kaggle corpus, F1 dropped from 0.992 to 0.304, and to 0.354 on SpamAssassin. The model keeps predicting legitimate on unseen phishing so the accuracy still looks acceptable, while most of the phishing class is missed. None of the reviewed papers evaluate with a cross corpus protocol, so the reported numbers likely overstate the real world performance.

Second, aggregated datasets leak between benchmarks. The direction from Kaggle to SpamAssassin barely dropped in our test (F1 0.972) which is suspicious rather than impressive, the Kaggle set is an aggregate of several older collections and very likely shares emails with SpamAssassin. No paper checks for this overlap, so even the few cross dataset claims that exist are not fully reliable.

Third, the public corpora are old and contain no AI generated phishing. Enron and SpamAssassin come from the early 2000s and the Nazario feed covers mostly 2015 to 2024. Although [1] proved that LLM written phishing works on humans, there is no public benchmark that contains such emails, so nobody can say how current detectors handle the attacks that are actually growing right now.

Fourth, spam and phishing labels are conflated between the benchmarks. SpamAssassin marks ordinary junk mail as positive while Nazario contains only credential phishing, and [3] excluded spam on purpose. Every paper defines the positive class in a different way, so the numbers are not comparable between papers.

Fifth, the trade-off between accuracy, robustness and cost is never quantified in one place. In our zero shot test the small llama-3.2-3b stayed stable at 0.80 to 0.84 accuracy on all three corpora without seeing any training data, while the classical models collapsed outside their own corpus. The bigger gemma-3-12b was actually worse, its precision fell to 0.58 because it flags almost every mail as phishing. And the cost was about half a cent per thousand emails. So a deployment decision depends on three axes at once, but no paper reports them together.

4 Objectives

The overall goal of the project is to measure, on a five dollar budget, how far small open LLMs can go for phishing email detection when the evaluation is done properly across corpora and with cost on the table. The specific objectives are:

1. Build a unified cross corpus benchmark from the free public datasets (Kaggle phishing set, SpamAssassin, Nazario with Enron ham), with a deduplication step between the corpora so that the leakage we observed in the preliminary experiments cannot inflate the results.
2. Evaluate classical baselines and small open LLMs (zero shot and few shot through OpenRouter) with a leave one corpus out protocol, so every model is always tested on a corpus it never saw.
3. Improve the small LLM with cheap methods only, better prompts, few shot examples selected from the training corpora, and a lightweight locally trained DistilBERT for comparison, no expensive teacher model like in [4].
4. Generate a small set of LLM written phishing emails (for evaluation only) and measure how much every detector degrades on them, this addresses the missing AI generated phishing in public benchmarks.
5. Report accuracy, cross corpus robustness and cost per thousand emails in a single table, and manually check the explanation quality of the LLM verdicts on a sample, following the concern raised by [5].

Expected outcome is a reproducible benchmark with codes and scripts, a results table that shows the three axes together, and a short analysis of where small models fail. The work plan is roughly, weeks 1 and 2 for the benchmark and deduplication, weeks 3 to 5 for the main experiments, week 6 for the AI generated test set, and the remaining time for analysis and report writing. All experiments run on our own laptops, the only paid resource is the OpenRouter API and based on the preliminary run the total cost will stay far below five dollars.

References

1. F. Heiding, B. Schneier, A. Vishwanath, J. Bernstein and P. S. Park, “Devising and Detecting Phishing Emails Using Large Language Models,” *IEEE Access*, vol. 12, pp. 42131–42146, 2024.
2. T. Koide, N. Fukushi, H. Nakano and D. Chiba, “ChatSpamDetector: Leveraging Large Language Models for Effective Phishing Email Detection,” arXiv:2402.18093, 2024.
3. M. A. Uddin, M. Mahiuddin and I. H. Sarker, “An Explainable Transformer-based Model for Phishing Email Detection: A Large Language Model Approach,” arXiv:2402.13871, 2024.
4. Z. Lin, Z. Liu and H. Fan, “Improving Phishing Email Detection Performance of Small Large Language Models,” arXiv:2505.00034, 2025.
5. S. Kuikel, A. Piplai and P. Aggarwal, “Evaluating Large Language Models for Phishing Detection, Self-Consistency, Faithfulness, and Explainability,” arXiv:2506.13746, 2025.